

Assessment Cover Sheet

Student ID Number/s:	Student Last name/s:	Student First name/s:
SHEA25113	RANABHAT	Hari
Course: Information Technology Project Part A		
Unit code: PROF909	Unit title: Information Technology Project Part A	
Due date: 04/08/2026	Date submitted: 04/08/2026	
Lecturer's Name: Babak Amiri		Tutor: Babak Amiri
Public GitHub URL: https://github.com/harirnb/GenAI-Cybersecurity-and-Privacy-Readiness-Assessment		

Table of Contents

Executive summary	3
Introduction	3
Evidence Review summary and Gap Analysis	4
Problem statement	5
Aim and objectives	6
Proposed solution	7
Methodology/ Delivery Approach	13
Project plan	15
Risk Management	16
Ethics, privacy and Responsible AI	17
Sustainability and social impact.....	18
Stakeholder and communication plan	18
Conclusion	19
References	20
Appendix A – Updated project charter	23
Appendix B – Detailed Gantt Chart	24
Appendix C – full Risk Register	24
Appendix D- RACI Matrix.....	26
Appendix E- AI Use statement	27

Design and evaluation of a Generative AI Cybersecurity and Privacy Readiness Assessment Framework for Australian organisations

Executive summary

Generative artificial intelligence is becoming part of normal organisational work, but adoption is moving faster than practical governance. The National AI Centre reported that 44% of Australian small and medium enterprises had adopted AI by February 2026, while trust clarity and knowing where to begin remained material barriers (National AI Centre 2026a). Employees can obtain immediate productivity benefits from public or externally hosted tools, yet informal property. Connected AI tools also introduce risks such as prompt injection, excessive permissions, unsafe generated outputs and weak supplier visibility.

This report recommends the design, development and evaluation of a Generative AI cybersecurity and privacy Readiness Assessment Framework for Australian SMEs and mid-sized organisations. The artefact will translate guidance from NIST CSF 2.0, NIST AI RMF, the OAIC, the Australian Cyber Security Centre, OWSAP, the National AI Centre and ISO/IEC 42001 into 30 practical questions across six domains. A browser-based prototype will apply domain weights, evidence caps and critical control gates to produce a four-level maturity result domain scores, priority gaps and an improvement roadmap.

Design Science Research will guide the project because main output is an artefact that must be evaluated, not only a literature review. And the evaluation will be a combination of an expert rating and quantitative discrimination tests, two synthetic organisational scenarios in the case a pilot organisation is not available for assessment.

Introduction

Tools of general-purpose use, for example ChatGPT, Microsoft Copilot and Gemini, are already being used to draft summarise code, analyse and undertake ad hoc knowledge work. The low cost of entry means that their benefits can be obtained without a formal technology project, procurement review and security assessment. Here in Australia, by February 2026, 44% of sales to SME organisations included AI adoption, and core adopters, whilst still experimenting on their own terms, had moved on to more widespread adoption (National AI

Centre 2026a). While this increases the value created by AI, it also increases the inherent need for recognised ownership, assurances for safe use, data controls and proportionate oversight. The risk is not just to the AI system. The social-technical system includes employee prompts; uploaded documents; connected APIs; external providers; policies, contracts & incident processes. An employee can accidentally PII into a public chat bot; log-in with a personal account; respond to insecure model-generated code or appoint a connected assistant to undertake unsafe actions. In 2024 the OAIC confirms section 14 of the privacy Act and the Australian privacy Principles include AI-generated personally identifiable information but recommend sticking to private tools (OAIC 2024a). The NIST and OWASP Like that identify governance, information disclosure, prompt injection, supply-chain & unsafe output risks (NIST 2024a; OWASP 2025). This paper now progresses from problem identification to outlining a practical response to the problem for Part B. It enhances the evidence and gap analysis template from Assessment 1; further narrows down the problem to a measurable problem; establishes SMART objectives; determines the proposed artefact and scoring model; explains the rationale for the approach; and presents the project plan, risk controls ethics sustainability and stake holder arrangements.

Evidence Review summary and Gap Analysis

Five finding emerge form the evidence, and they are connected in ways worth unpacking

Let's start with adoption. Organisations are moving toward GenAI because the productivity case is obvious, but governance hasn't caught up in the same way. The National AI Centre's advice covers the expected ground: accountability, AI registers, testing, monitoring, human oversight, supply chain controls. Importantly though, it also concedes that these practices need to flex depending on an organisation's size and risk appetite (National AI Centre 2026b;2026c). that concession matters more than it might first appear. It means showdown AI use, staff quietly using tools that haven't been sanctioned isn't simply a discipline problem. More often it is a signal. People have work to do, and the approved tools, policies, or alternatives on offer aren't meeting that need.

Then there's the risk picture, which is really two risk pictures layered on top of each other's. Traditional cyber controls haven't gone away least privilege, identify management, logging, secure configuration, incident response are still doing work. But GenAI opens up something new. OWASP's rundown of the leading risks facing LLM applications includes prompt injection, sensitive information disclosure, supply chain weakness, data and model poisoning, poor output handling, and excessive agency (OWASAP 2025). None of the that is speculative. Shokri et al. (2017) and Carlini et al. (2021) both demonstrated, empirically, that models can leak training data through membership inference attacks and outright memorisation. So, the Privacy risks are real, not theoretical. Still, for the average organisation adopting these tools day to day, the bigger problem is usually less exotic: someone pastes confidential information into a prompt, generated code goes into

production without review, an output gets trusted more than it should, an integration is set up without proper controls.

Privacy law adds another layer, and it applies across the whole lifecycle of AI use not just at the point where a tool gets switched on. The OAIC's expectations are fairly comprehensive: due diligence, privacy by design, minimising the personal information collected, understanding what providers actually do with data where it's stored, who else touches it, whether it crosses borders and keeping a human meaningfully in the loop (OAIC 2024a). One point that's easy to miss is information an AI system infers or generates about someone can itself be regulated personal information, even if nobody typed it in directly. Which is why contracts, configuration settings and retention and deletion practices end up being as much a privacy question as a security one.

The guidance landscape itself is the fourth issue: there's plenty of it, but it doesn't sit together neatly. NIST CSF 2.0 gives cybersecurity outcomes across six functions: govern, identify, protect, detect, respond, recover (NIST 2024b). Sitting alongside it, then, the NIST AI RMF offers its own structure that is Govern, Map, Measure, Manage aimed specifically at trustworthy AI, and the GenAI profile builds on that further for generative systems (NIST 2023; 2024a). Add ISO/IEC 42001's management system approach, the ACS code's professional values, and various pieces of Australian privacy and adoption guidance and what you get is genuinely useful material that does not add up to one coherent, measurable assessment particularly not for an SME trying to work out where it stands.

That's the reason three separate gap analysis methods were used here, each aimed at a different question rather than repeating the same one. Comparing current state against expected state using NIST CSF 2.0 turned up weak ownership, patchy AI inventories, thin GenAI-specific protections, and response arrangements that aren't really mature yet. A likelihood impact matrix pulled out the highest priority exposures of sensitive data disclosure, shadow AI, provider risk, prompt injection, over-trusted output. And a five whys analysis took what looked on the surface like ordinary employee error and traced it back further; unclear policy, not enough training, no approved tool actually available, accountability split across teams, and adoption simply outrunning governance.

Put the three together and a practical gap comes into focus not a conceptual one. Australian organisations don't currently have a simple, evidence-based, repeatable way to work out how ready they are on GenAI cybersecurity and privacy: here their maturity actually sits, or what to fix first.

Problem statement

The project addresses Australian SMEs and mid-sized organisations that allow, tolerate or are beginning to manage employee use of GenAI tools but do not have a dedicated AI

governance capability. CIO, CISO, privacy officer, risk manager or IT manager are the immediate users who need a structured view of current readiness. Unsafe use of AI can expose confidential or personal information, produce outputs, weaken trust or create intrusive monitoring practices this can directly affect the employees, customers or other individuals. Existing guidance describes good practices, but organisations may still be unable to answer practical questions such as Who owns GenAI risk? Which tools and accounts are in use? What information enters them? Which evidence demonstrates that a controls operates? Which gaps must be fixed first? Without these answers, an organisation can mistake a policy document or an enterprise license for genuine readiness.

The project is deliberately limited to employee use of externally provided GenAI tools in Australian organisational settings. It will not provide legal advice, certify compliance, test the security of commercial providers, train a new AI model or deploy a production enterprise platform. This boundary keeps the work feasible within Part B and concentrates on the gap established by the evidence that is translating fragmented guidance into a repeatable readiness score and improvement roadmap.

Aim and objectives

The aim is to design, develop and evaluate a practical Generative AI Cybersecurity and Privacy Readiness Assessment Framework that enables Australian SMEs and organisations to measure control maturity, identify priority risks and develop a targeted improvement roadmap for the secure use of external GenAI tools.

The four objectives are mapped to measure Part B milestones:

1. By the end of week 3, produce a traceable control library containing 30 readiness questions across six domains, mapped to selected NIST, OAIC, OWASP, National AI centre and ISO/IEC 42001 sources.
2. By the end of week 5, define a four level; maturity model with 0-4 control criteria, evidence requirements, domain weights and critical control gates that prevent unsupported ratings from inflating readiness.
3. By the end of week 7, I will deliver a working browser which can calculate domain and overall scores, I will also identify at least six priority gaps and generate an order improvement roadmap without uploading or storing organisational responses.
4. At the end of week 9, I will evaluate the framework using deterministic scoring test, I will use two synthetic organisational scenarios and structured feedback form at least two informed reviewers, achieving an average of clarity and usefulness rating at least 4 out of 5 before final refinement in week 10.

Proposed solution

For my project, I am developing a simple Generative AI Readiness assessment tool. The goal is to help an organisation figure out whether it's actually ready to use Generative AI safely and responsibly. The artefact has four main parts they are: the controls questions, the maturity levels, the scoring process and the final report. I wanted to keep it lightweight since it is meant for an early-stage review that means something can be run as a self-assessment or with a bit of outside help, but it is not meant to replace a proper audit. AI readiness is not just a technical problem that's why I choose this topic. An organisation can have solid cybersecurity and still fall down on employee training, privacy, unclear ownership or staff quietly using AI tools that were never approved. This assessment doesn't just look at technology it also covers governance, people, data handling, and third party providers.

The questionnaire has 30 questions across six areas that are governance and accountability, AI inventory and use case control, privacy and data handling, cybersecurity safeguards, people and human oversight and third-party management, monitoring and incident response. Each question is tied to a recognised framework, standard or government source. I did so the organisation can see why questions are being asked and so the assessment is easier to update later if laws, standards or AI guidance change. The questions also ask for supporting evidence things like an AI policy and AI register, staff training records, supplier review documents, access control settings, or an incident response procedure. Nothing needs to actually be uploaded for the Part A prototype; the user just indicates whether the evidence is unavailable, partly available or verified.

Controls are scored 0 to 4: 0 means the control doesn't exist, 1 means it is only planned or handled informally, 2 means it's partly implemented, 3 means it's documented and operating, and 4 means it's measured and improved over time. During panel feedback, someone raised a fair concern the maturity scoring felt too generous, since a user could give themselves a high score with nothing to back it up. I agreed relying on the selected score alone risked making the result misleading.

To fix this, I added an evidence cap. With no evidence, the effective score can't go above 1. With partial evidence, it caps at 3. The full score only applies once the evidence is verified. So, if an organisation claims its AI policy is fully implemented and rates itself a 4, but can't actually produce the policy or any supporting documentation, the system pulls that score back down. It is a way of keeping the result honest and stopping organisations from overestimating how ready they really are. I also flagged six controls as critical having an accountable AI owner, maintaining an AI inventory, applying data classification rules, providing role-based training, reviewing suppliers and having an AI related incident responses process.

These act as maturity gates. An organisation can't be rated managed if any critical control scores below 2 and cannot reach optimised if any of them sit below 3. I added these gates because a good average can hide a serious gap. An organisation might score well on training and technical security but have literally no one accountable for AI decisions, and without the gates, that weakness would just get buried under stronger scores elsewhere.

Each assessment area carries a different weight which is governance and accountability, privacy and data handling and cybersecurity safeguards are each weighted at 20%. AI inventory and use case control and third-party management/monitoring/incident response are each 15%. People, policy, and human oversight sit at 10%. I weighted governance, privacy and cybersecurity more heavily because weaknesses their trend to carry the greatest organisational risk through the other areas still matter, since responsible AI use is about more than just technical controls.

The system combines the weighted domain score into an overall result from 0-100: 0-24 is Ad hoc, 25-49 is Basic, 50-74 is managed and 75-100 is optimised. But the score alone doesn't decide the final level the system also checks the critical controls, so an organisation could land in the managed range numerically and still get placed at Basic if a key control is missing. The final output is aimed at management. It shows the overall score, the maturity level, the percentage for each assessment area, and the weakest controls, plus six recommended actions based on the lowest scoring areas things like appointing an AI owner, building and AI register, settings rules for sensitive data, rolling out staff training, reviewing a supplier or updating the incident response plan. I wanted the recommendations to feel practical rather than just a list of problems so where possible they also point to who might own the fix governance actions going to senior management, security actions to IT/cybersecurity, privacy actions to a privacy, legal or risk officer.

For part A, I built the prototype in HTML, CSS and JavaScript with no backend or database everything runs and stays in the browser. The point of this first version is to test whether the questions scoring rules, and report actually work, not to build out accounts or storage which would add scope without adding much value at this stage. Keeping everything local also sidesteps privacy concerns, since no one of the organisation's response leave the browser though it does mean the current prototype cannot save past assessments or support multiple users. In part B, I plan to refine the question wording, review the source mappings, stress test the maturity rules, and improve the report layout and check whether the evidence requirements make sense to users without a technical background.

The final version will include a clear limitations statement: the tool supports decision making but it isn't legal opinion, formal audit, a compliance certificate or proof that an organisation has met every legal requirement.

The main value of the artefact is giving an organisation a starting point. Rather than working through a stack of framework separately, management can run one structured assessment

and see straight away where to focus first feeding into decisions on training, policy, security controls, privacy, supplier management and future assurance work.

Assessment domain	weight	Primary coverage
Governance and accountability	20%	Accountable owner, policy, cross functional governance, decisions and review
AI inventory and use case control	15%	Tools, accounts, owners, use case, data flows, integrations and rationalisation
Privacy and data handling	20%	Data classification, APP-aligned use, notices, retention and privacy impact assessment
Cybersecurity safeguards	20%	Identity, prompt injection, output validation, logging, DLP and secure configuration
People, policy and human oversight	10%	Training, acceptable use, approved alternatives, review and reporting
Third parties, monitoring and incident response	15%	Due diligence, contracts, change review, incident playbooks and proportionate monitoring

Table1- proposed assessment domain and initial weights

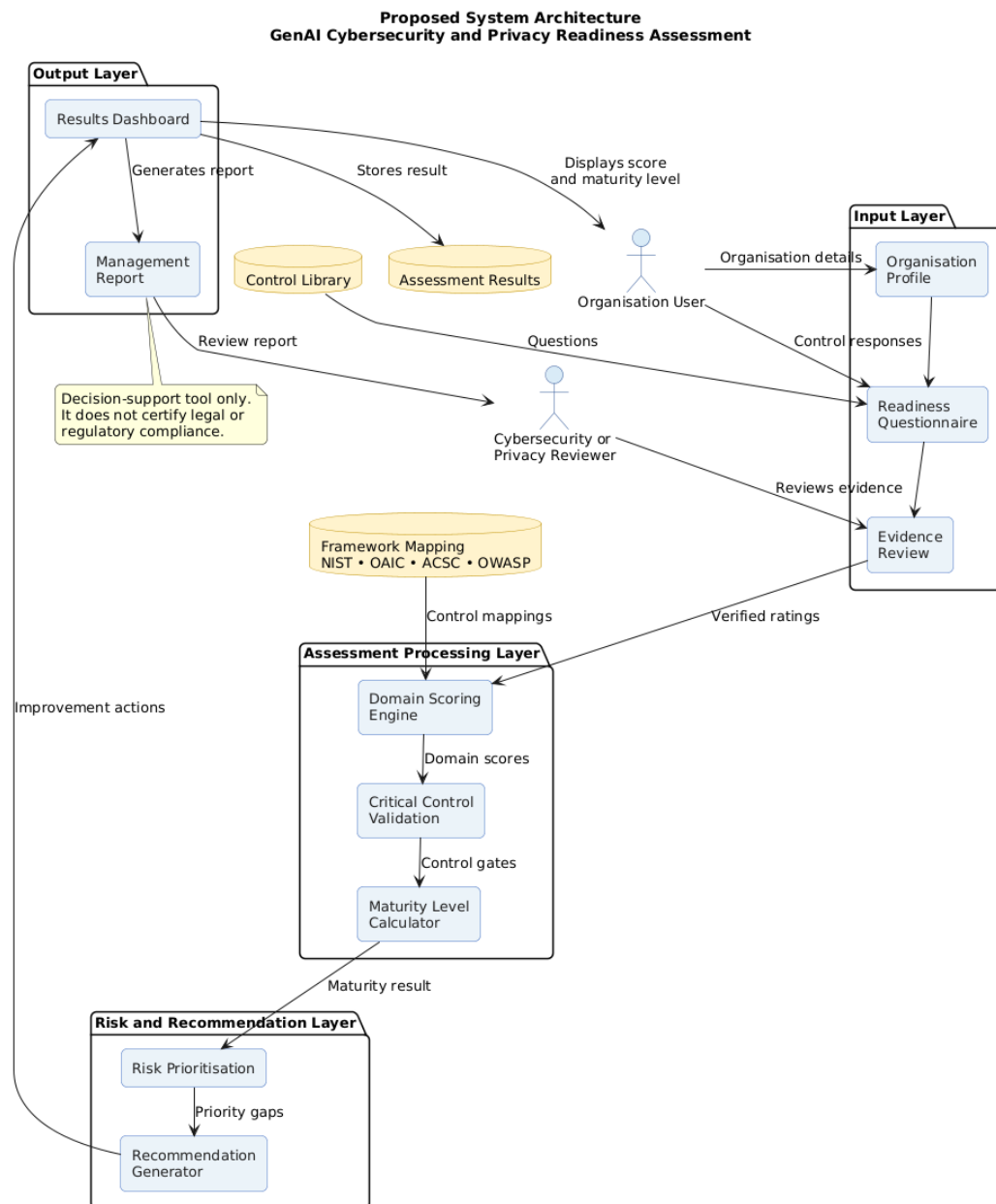


Figure 1: proposed layered system architecture for the GenAI readiness assessment.

Use-Case Diagram
GenAI Readiness Assessment System

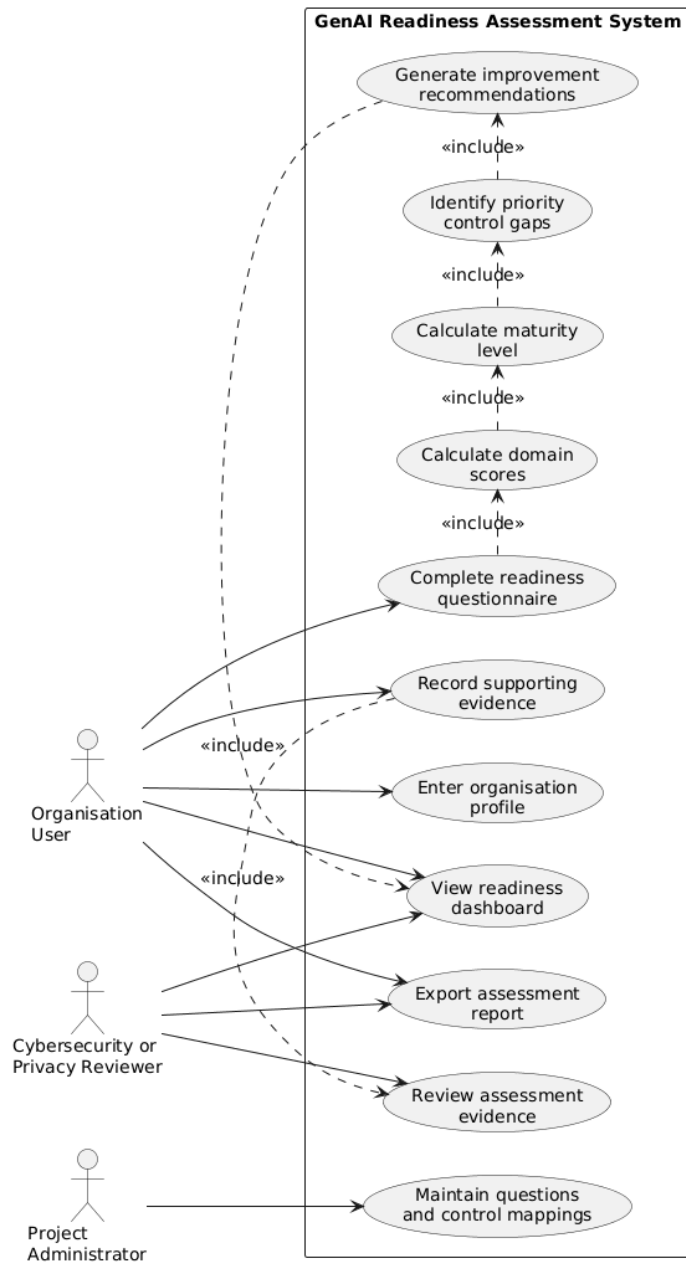


Figure 2: primary actors and system use cases for the proposed porotype

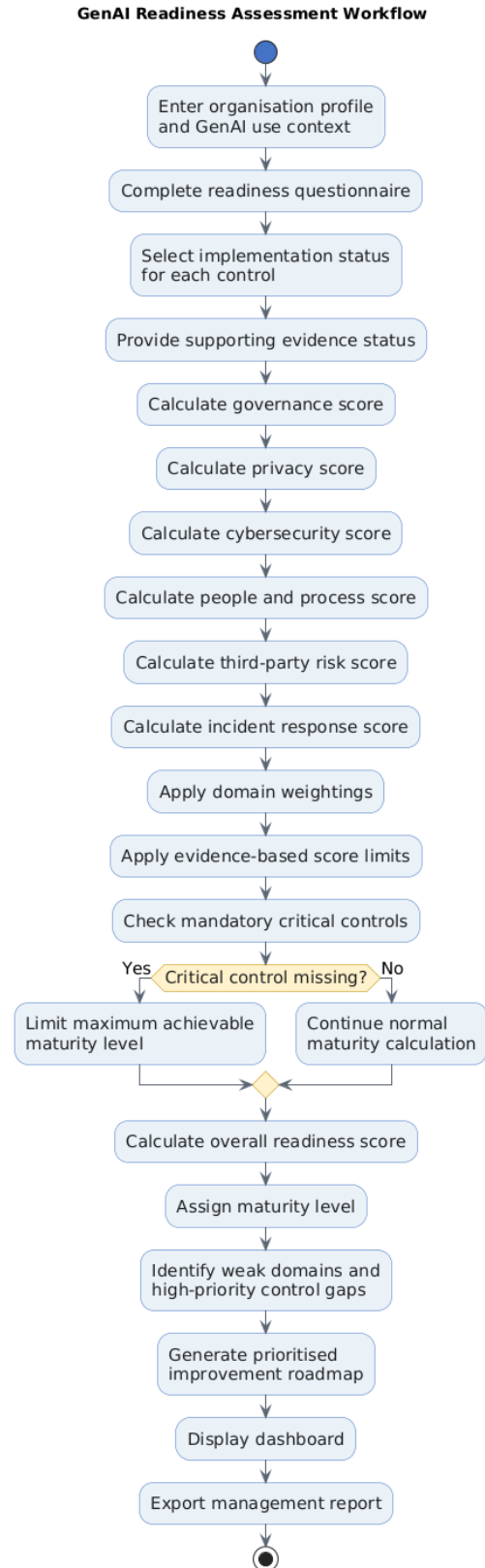


Figure 3: end to end workflow used to calculate readiness and generate a prioritised roadmap

Figure 1 to 3 show the solution from three different viewpoints. The architecture identifies the main system layer; the use case diagram clarifies who interacts with the prototype and the workflow shows how response move from the questionnaire to the maturity result and improvement roadmap.

Weighted score	Initial maturity	interpretation
0-24	Ad hoc	Controls are absent, informal or person dependent
25-49	basic	Some foundations exist but are inconsistent or weakly evidenced.
50-74	managed	Core controls are documented and operating, subject to critical gates.
75-100	optimised	Controls are evidenced, measured and continually improved, subject to critical gates.

Table2: initial maturity bands, subject to critical control gates

Methodology/ Delivery Approach

Design Science Research (DSR) is the primary methodology because the project responds to an identified organisational problem by creating and evaluating an artefact. Hevner et al. (2004) distinguish design science from explanatory behavioural research by emphasising purposeful artefacts that improve problem environment. Peffers et al. 2007 provide a practical six stage processes which are problem identification and motivation, objectives for a solution, design and development, demonstration, evaluation and communication. This sequence closely matches the project need.

Problem identification is established through the assessment 1 evidence review, NIST CSF comparison, risk matrix and Five Whys analysis. Objectives are translated into requirements for six domains, 30 traceable questions, four maturity levels, evidence caps, critical gates, local processing and management outputs. Design and development will create the

questionnaire framework crosswalk, scoring rules, prototype and report format. Demonstration will apply the tool to two synthetic organisational scenarios one with informal public tool use and low governance maturity, and another with approved enterprise tools but incomplete supplier and incident controls.

Evaluation will test cases will confirm that the same inputs always produce the same scores, domain calculations are correct maturity gates operates as specified. Finding will be recorded, prioritised and traced to design changes. Figure 4 summarises this build evaluate refine cycle. Agile task management will support execution through a GitHub backlog, weekly planning, short development increments and regulate review. However, pure scrum is not selected as the main methodology because shipping features is not the primary success criterion; the important result is whether the artefact is evidence based and useful. A pure literature review methodology is also insufficient because the project must build and evaluate a working capability. DSR therefore provides the research logic, while Agile practices provide transparent delivery discipline.

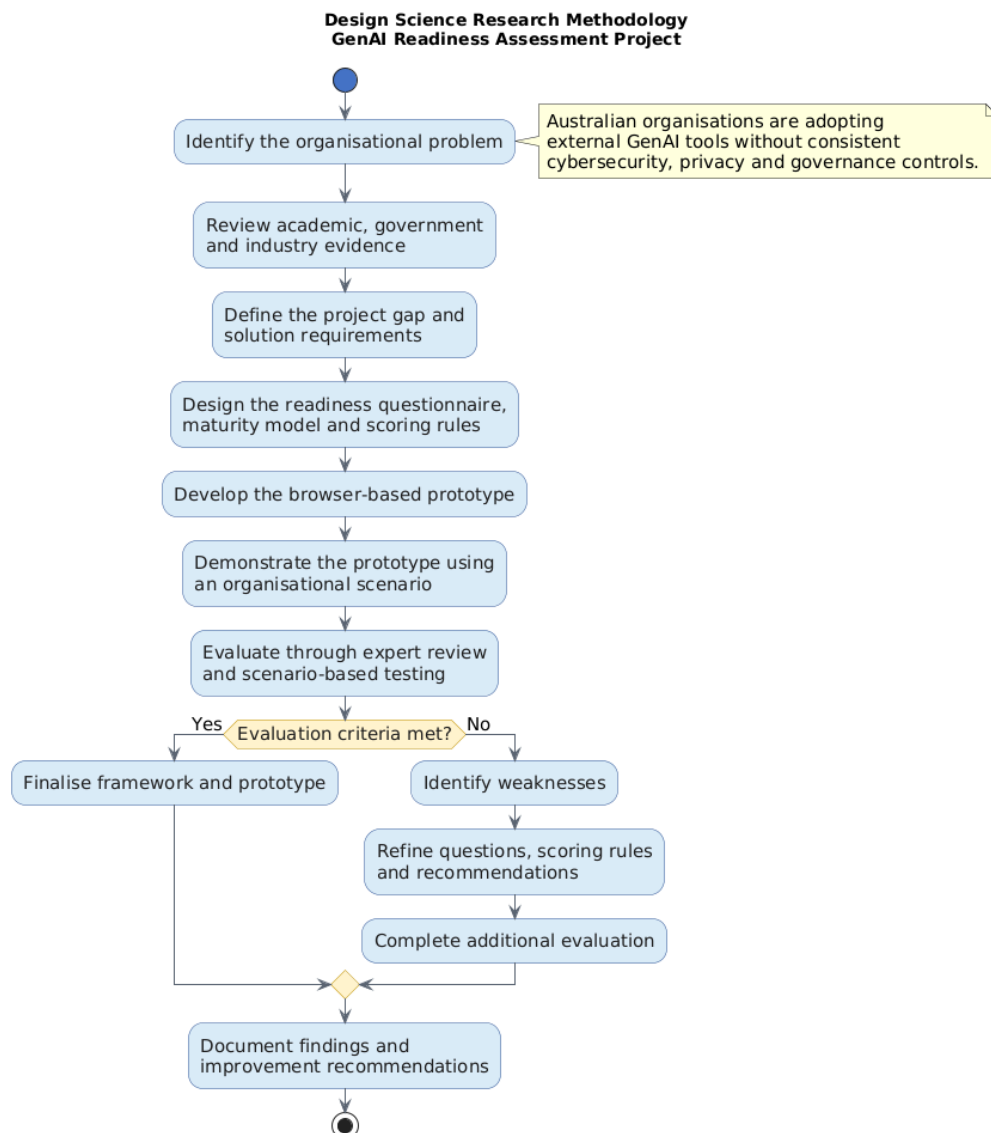


Figure 4: design science research methodology with an evaluation and refinement loop

Project plan

The project is planned as approximately 300 hours across ten-part B weeks, within the expected scope for a sole master's project. I have divided work into five different work packages which are evidence and requirements, framework design, prototype development, evaluation and final handover. The three level WBS identifies the deliverables and lower-level tasks, while the Gantt chart shows timing of my works, dependencies, milestone and critical path. Week 1-2 I will re confirm the scope after Assessment 3 feedback update the source register, recruit reviews and approve success criteria. Weeks 2-4 will refine the 30 questions and complete framework to control traceability. Scoring design begins once domains and questions are stable, with evidence caps, weights and maturity gates completed by week 5. Dashboard and report design can run partly in parallel, but prototype development depends on the scoring specification and is scheduled for weeks 5-6. Functional, manual calculation and accessibility testing follow in week 6-7.

Evaluation is the main delivery dependency. Reviewer recruitment starts early because expert access cannot be assumed. Review materials and synthetic scenarios will be prepared before the week 7 prototype milestone. Expert review and scenario testing occur in weeks 7-8, followed by analysis and design refinement in week 8-9. Week 10 is reserved for final documentation, portfolio quality, handover and submission rather than unfinished development.

The critical path is scope confirmation, control mapping, scoring model, prototype, evaluation, refinement, final handover. If time is lost, optional interface polish will be reduced before the scoring model or evaluation is weakened. Resources include the student's laptop, GitHub, document and diagram tools, official framework publications, browser development tools, the academic supervisor and two informed reviewers. No paid cloud platform or sensitive organisational dataset is required.

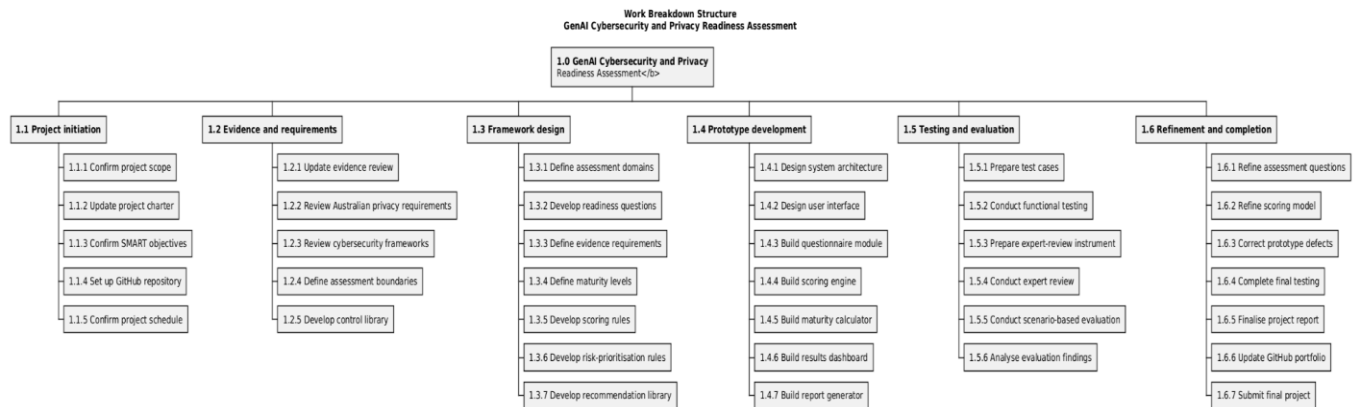


Figure 5: three level work breakdown structure

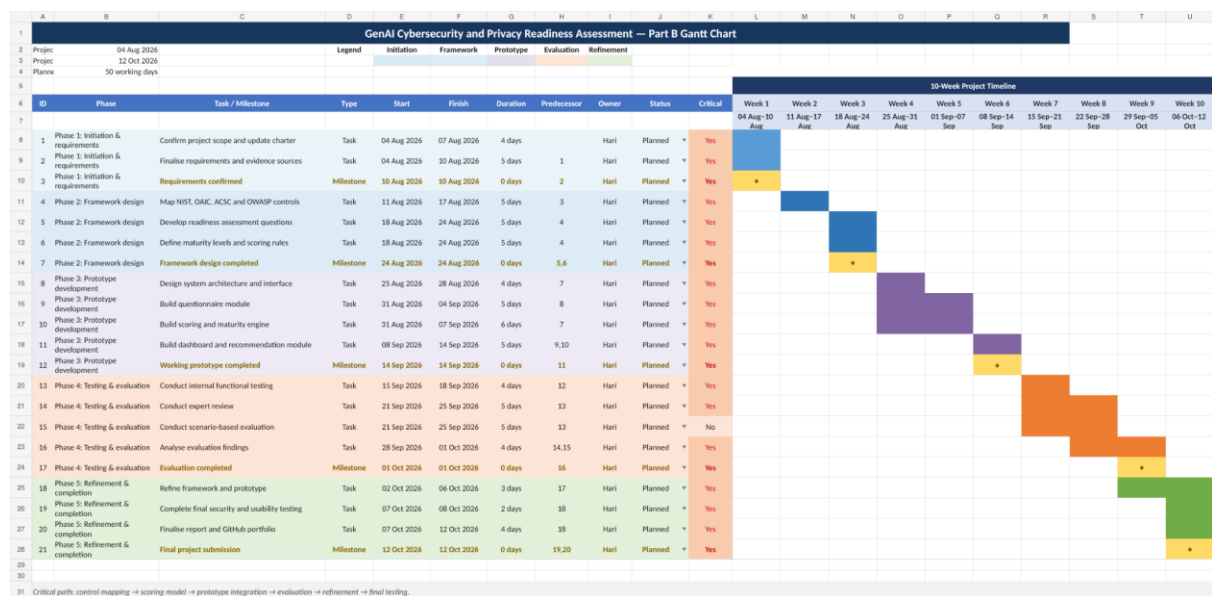


Figure 6: ten-week Gantt chart

Risk Management

Risk management follows a 1-5 likelihood and impact scale, with treatment focused on actions that can be verified. The highest risks are subjective scoring, scope creep, lack of pilot access, schedule slippage and incorrect interpretation of regulatory guidance. These are controlled through fixed scope guardrails, evidence caps, critical gates, source traceability, early reviewer recruitment and a scenario-based evaluation fallback. Privacy and confidentiality risks are reduced by using synthetic data and a local browser prototype. A public repository review will check for secrets or identifying information before release. Personal workload is included because unrealistic hours could damage both quality and well-being. The risk register will be reviewed weekly and after any change to scope, reviewers' access, evidence or technology.

ID	Priority risk	L	I	Score	Primary treatment
R2	Subjective/inflated maturity scoring	4	5	20	Evidence caps, critical gates, documented criteria and expert review
R1	Scope creep across frameworks and use cases	4	4	16	Fixed scope, change gate and deferred feature list
R3	No pilot organisation	4	4	16	Recruit early; expert review and synthetic scenario fallback
R8	Schedule slippage	4	4	16	Critical path review; reduce optional UI polish first
R6	Incorrect regulatory interpretation	3	5	15	Official sources traceability and decision support disclaimer
R12	Workload and wellbeing pressure	3	4	12	Weekly workload cap, buffer and early supervisor escalation

Table 3: summary of priority project risk.

Ethics, privacy and Responsible AI

The project is guided by the ACS code of professional Ethics, particularly honesty, trustworthiness and respect (ACS 2023). It also applies the Australian Privacy Principles, the NIST AI RMF functions of govern, map, measure and manage, Australia’s AI Ethics Principles and the National AI centre’s emphasis on accountability and human oversight. These frameworks are used to shape the artefact rather than being listed as general aspirations.

The central ethical Delima is the tension between security visibility and employee privacy. Organisations need enough monitoring to identify sensitive uploads, unsafe integrations and policy violations. However, broad or covert monitoring can capture personal activity, create unfair investigations and reduce trust. The framework treats monitoring as acceptable only when it necessary, proportionate and transparent. Relevant assessment questions require a documented purpose, employee notice, restricted access, limited retention, fair escalation and periodic review. The tool does not reward an organisation merely for collecting more data; it rewards governance and defensible safeguards.

Privacy by design is also integrated into the prototype. It operates locally in the browser, requires no names or operational secrets, and does not upload or retain response. Part B

evaluation will use synthetic scenarios wherever possible. If reviewers provide professional comments, only the minimum necessary contact and feedback data will be collected, stored securely and removed after academic purpose is complete. Any future organisational pilot would require participant information, permission to use organisational material and removal of identifying details from the public repository.

Sustainability and social impact

Sustainability was considered when planning the project, particularly its environmental, social and economic impact. In terms of the environment, the prototype is only a small static web application that can run locally on a computer. It does not train a large AI model or depend on cloud-based processing. Because of this, it should use less computing power, storage and internet data than a more complex AI system.

The social impact of the project is mainly connected to how organisations manage the use of GenAI. Framework does not suggest organisations should completely ban AI tools, as employees may still find ways to use them without approval. It focuses on practical steps such as staff coaching, clear responsibilities and access to approved tools. Any monitoring should also be reasonable and openly explained rather than being carried out without employees knowing. The interface will be checked against relevant WCAG 2.2 guidance. Basic features such as clear labels, keyboard navigation and a layout that works on different screen will be considered during development (W3C 2023).

The project also considers cost. Some smaller organisations may not have enough money, staff or time to introduce every recommended control immediately. For that reason, the framework will show which areas should be addressed first based on the organisation's risks and current maturity. This allows an organisation to begin with the most necessary controls and make further improvement over time. Taking this approach may help reduce the likelihood of data breaches, privacy concerns, legal issues and damage to the organisation's reputation.

Stakeholder and communication plan

Communication must be specific; stakeholders have different interests and influence. The academic supervisor has high influence over scope and academic quality and will receive a structured weekly progress summary. Cybersecurity and privacy reviewers have medium to high influence over technical credibility and will receive a concise review pack, demonstration and feedback form during week 7-8. A potential pilot organisation representative has high practical interest but uncertain availability; contact will focus on scope, confidentiality and whether the output is understandable. End user reviewers will assess clarity and usability rather than legal correctness.

stakeholder	interest	influence	Mechanism/content	frequency
Academic supervisor	medium	high	Weekly meeting or progress summary; artefact review	weekly
Cybersecurity expert reviewer	high	medium	Structured review pack, demo and feedback form	Week 7-8
Privacy/governance expert reviewer	high	medium	Control/evidence review and short interview	Week 7-8
Potential pilot organisation representative	high	high	Scope and confidentiality discussion; scenario or pilot demo	Three milestone contacts
End user reviewer	high	low	Guided usability session and five-point rating form	Once during evaluation
Project lead/student	high	high	GitHub issues, decision log and weekly retrospective	continuous

Table 4: stakeholder interest, influence and communication arrangements

Conclusion

This proposal commits to a focused and feasible of the project: an evidence based GenAI cybersecurity and privacy readiness framework, a working local prototype an a documented evaluation. The artefact will convert multiple sources of guidance into measurable controls, evidence expectations, maturity gates and prioritised improvement actions without presenting itself as a compliance certificates. In next part week 1 will begin by reviewing feedback of this assessment reconfirming the six domains scope, updating the source register, recruiting two reviewers and converting the submitted backlog into the first active sprint.

References

Australian Computer Society (ACS) 2023, Code of Professional Ethics, ACS, viewed 29 July 2026, <<https://www.acs.org.au/memberships/professional-ethics-conduct-and-complaints.html>>.

Australian Cyber Security Centre (ACSC) 2024, Engaging with artificial intelligence, Australian Signals Directorate, viewed 29 July 2026, <<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/engaging-with-artificial-intelligence>>.

Australian Government 2019, Australia's AI Ethics Principles, Department of Industry, Science and Resources, viewed 29 July 2026, <<https://www.industry.gov.au/publications/australias-ai-ethics-principles>>.

Batool, A, Zowghi, D & Bano, M 2024, 'Responsible AI governance: a systematic literature review', arXiv preprint, arXiv:2401.10896.

Carlini, N, Tramèr, F, Wallace, E, Jagielski, M, Herbert-Voss, A, Lee, K, Roberts, A, Brown, T, Song, D, Erlingsson, U, Oprea, A & Raffel, C 2021, 'Extracting training data from large language models', 30th USENIX Security Symposium, pp. 2633–2650.

Dwivedi, YK et al. 2023, 'So what if ChatGPT wrote it? Multidisciplinary perspectives on opportunities, challenges and implications of generative conversational AI for research, practice and policy', *International Journal of Information Management*, vol. 71, article 102642, doi:10.1016/j.ijinfomgt.2023.102642.

Feuerriegel, S, Hartmann, J, Janiesch, C & Zschech, P 2024, 'Generative AI', *Business & Information Systems Engineering*, vol. 66, no. 1, pp. 111–126, doi:10.1007/s12599-023-00834-7.

Gupta, M, Akiri, C, Aryal, K, Parker, E & Praharaj, L 2023, 'From ChatGPT to ThreatGPT: impact of generative AI in cybersecurity and privacy', *IEEE Access*, vol. 11, pp. 80218–80245, doi:10.1109/ACCESS.2023.3300381.

Hevner, AR 2007, 'A three cycle view of design science research', *Scandinavian Journal of Information Systems*, vol. 19, no. 2, pp. 87–92.

Hevner, AR, March, ST, Park, J & Ram, S 2004, 'Design science in information systems research', *MIS Quarterly*, vol. 28, no. 1, pp. 75–105.

ISO 2018, ISO 31000:2018 Risk management—Guidelines, International Organization for Standardization, Geneva.

ISO/IEC 2023, ISO/IEC 42001:2023 Information technology—Artificial intelligence—Management system, International Organization for Standardization, Geneva.

Jada, I & Mayayise, TO 2024, 'The impact of artificial intelligence on organisational cyber security: an outcome of a systematic literature review', *Data and Information Management*, vol. 8, no. 2, article 100063, doi:10.1016/j.dim.2023.100063.

Janssen, M 2025, 'Responsible governance of generative AI: conceptualizing GenAI as complex adaptive systems', *Policy and Society*, vol. 44, no. 1, pp. 38–51, doi:10.1093/polsoc/puae040.

McIntosh, TR, Susnjak, T, Liu, T, Watters, P, Nowrozy, R & Halgamuge, MN 2024, 'From COBIT to ISO 42001: evaluating cybersecurity frameworks for opportunities, risks, and regulatory compliance in commercializing large language models', *arXiv preprint*, arXiv:2402.15770.

Murugesan, S 2008, 'Harnessing green IT: principles and practices', *IT Professional*, vol. 10, no. 1, pp. 24–33, doi:10.1109/MITP.2008.10.

National AI Centre 2026a, AI adoption insights: December 2025 to February 2026, Department of Industry, Science and Resources, viewed 29 July 2026, <<https://www.ai.gov.au/news-and-insights/blog/ai-adoption-insights-december-2025-february-2026>>.

National AI Centre 2026b, Guidance for AI adoption: foundations, Department of Industry, Science and Resources, viewed 29 July 2026, <<https://www.ai.gov.au/staying-safe-and-responsible/essential-ai-practices/guidance-ai-adoption-foundations>>.

National AI Centre 2026c, Guidance for AI adoption: implementation guidance, Department of Industry, Science and Resources, viewed 29 July 2026, <<https://www.ai.gov.au/staying-safe-and-responsible/essential-ai-practices/guidance-ai-adoption-implementation-guidance>>.

National Institute of Standards and Technology (NIST) 2023, Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1, doi:10.6028/NIST.AI.100-1.

National Institute of Standards and Technology (NIST) 2024a, Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1, doi:10.6028/NIST.AI.600-1.

National Institute of Standards and Technology (NIST) 2024b, The NIST Cybersecurity Framework (CSF) 2.0, NIST CSWP 29, doi:10.6028/NIST.CSWP.29.

Office of the Australian Information Commissioner (OAIC) 2024a, Guidance on privacy and the use of commercially available AI products, updated 17 January 2025, viewed 29 July 2026, <<https://www.oaic.gov.au/privacy/privacy-guidance-for-organisations-and-government-agencies/guidance-on-privacy-and-the-use-of-commercially-available-ai-products>>.

Office of the Australian Information Commissioner (OAIC) 2024b, Guidance on privacy and developing and training generative AI models, viewed 29 July 2026,

<<https://www.oaic.gov.au/privacy/privacy-guidance-for-organisations-and-government-agencies/guidance-on-privacy-and-developing-and-training-generative-ai-models>>.

Open Worldwide Application Security Project (OWASP) 2025, OWASP Top 10 for LLM and GenAI Applications, viewed 29 July 2026, <<https://genai.owasp.org/llm-top-10/>>.

Papagiannidis, E, Mikalef, P & Conboy, K 2025, 'Responsible artificial intelligence governance: a review and research framework', *Journal of Strategic Information Systems*, vol. 34, no. 2, article 101885, doi:10.1016/j.jsis.2024.101885.

Peffers, K, Tuunanen, T, Rothenberger, MA & Chatterjee, S 2007, 'A design science research methodology for information systems research', *Journal of Management Information Systems*, vol. 24, no. 3, pp. 45–77, doi:10.2753/MIS0742-1222240302.

Schwaber, K & Sutherland, J 2020, *The Scrum Guide: The definitive guide to Scrum*, viewed 29 July 2026, <<https://scrumguides.org/>>.

Shokri, R, Stronati, M, Song, C & Shmatikov, V 2017, 'Membership inference attacks against machine learning models', *2017 IEEE Symposium on Security and Privacy*, pp. 3–18, doi:10.1109/SP.2017.41.

Taeihagh, A 2025, 'Governance of generative AI', *Policy and Society*, vol. 44, no. 1, pp. 1–22, doi:10.1093/polsoc/puaf001.

Weidinger, L et al. 2022, 'Taxonomy of risks posed by language models', *Proceedings of the 2022 ACM Conference on Fairness, Accountability, and Transparency*, pp. 214–229, doi:10.1145/3531146.3533088.

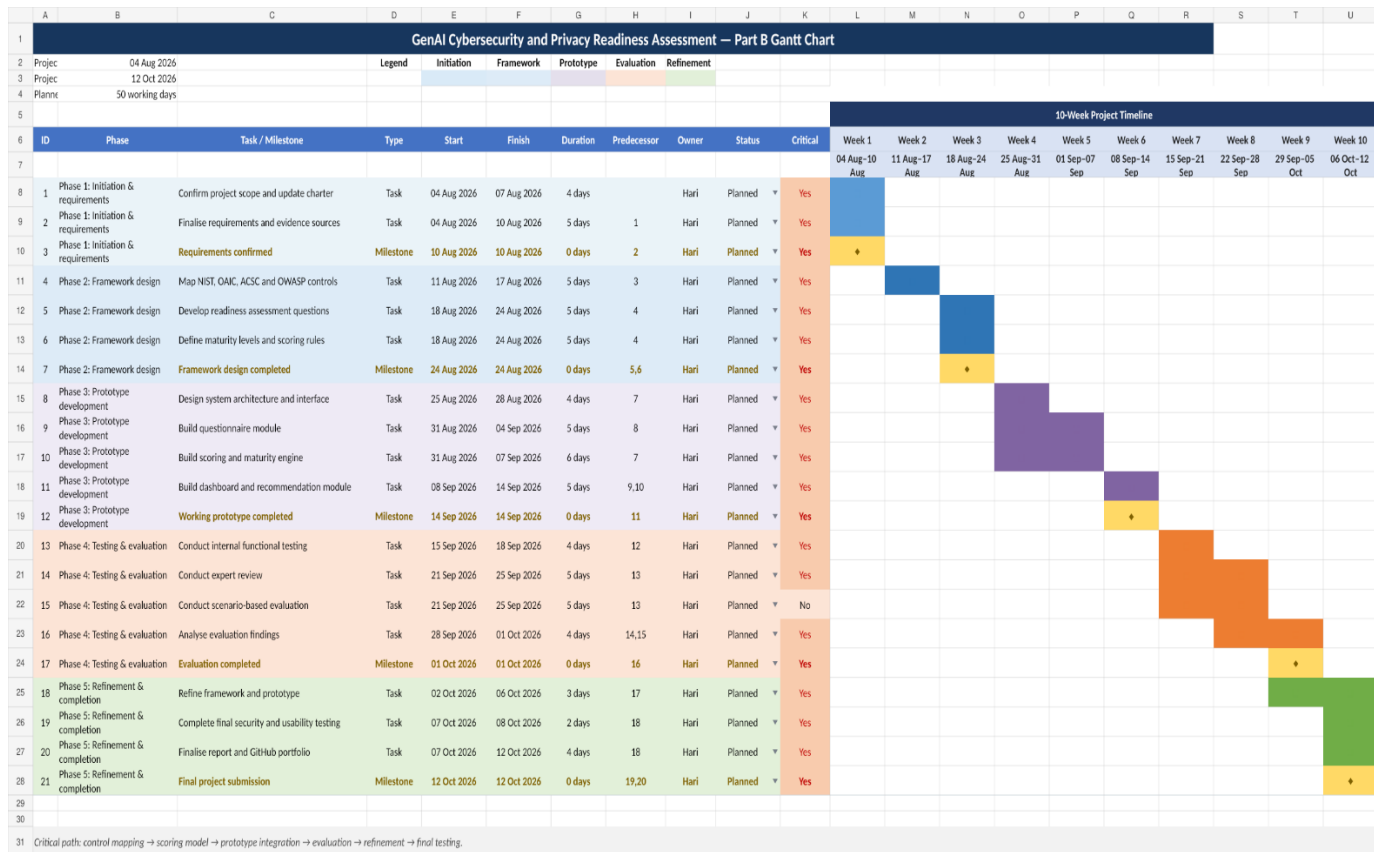
World Wide Web Consortium (W3C) 2023, *Web Content Accessibility Guidelines (WCAG) 2.2*, W3C Recommendation, viewed 29 July 2026, <<https://www.w3.org/TR/WCAG22/>>.

Ye, X, Yan, Y, Li, J & Jiang, B 2024, 'Privacy and personal data risk governance for generative artificial intelligence: a Chinese perspective', *Telecommunications Policy*, article 102851, doi: 10.1016/j.telpol.2024.102851.

Appendix A – Updated project charter

Element	Updated charter content
Project title	Design and evaluation of a generative AI cybersecurity and privacy readiness assessment framework for Australian organisation
problem	Australian SMEs and mid-sized organisations lack a measurable way to determine whether governance, cybersecurity, privacy, people and supplier controls are adequate for employee use of external GenAI tools.
Value proposition	Convert fragmented guidance into a evidence maturity result, major control gaps and a prioritised improvement roadmap
In scope	30 question; six domains; four maturity levels, evidence cap; critical gates; local browser prototype, expert review; two synthetic scenarios, management report format
Out of scope	Legal advice, certification, production deployment, penetration testing of providers, model training, enterprise roll out
stakeholders	Student/project lead, academic supervisor, cybersecurity reviewers, privacy/governance reviewer, potential organisation representative, end-user reviewer
deliverables	Framework, questionnaire, maturity rubric, control crosswalk, prototype, evaluation report, risk and RACI documents, public GitHub portfolio
Success measures	30 traceable questions; four defines levels; deterministic scoring; six priority recommendations; two informed reviewers; average clarity/usefulness $\geq 4/5$.

Appendix B – Detailed Gantt Chart



Appendix B figure: detailed Gantt chart.

Appendix C – full Risk Register

ID	Risk	L	I	Score	Owner	Mitigation	Contingency
R1	Scope expands across too many frameworks and use cases	4	4	16	Project lead	Fixed scope to employee use of external GenAI and six domains; formal change gate	Defer lower-priority features
R2	Maturity scoring is subjective or easy to inflate	4	5	20	Project lead	Evidence caps, critical gates, documented criteria and expert review	Revise weights and publish limitations

ID	Risk	L	I	Score	Owner	Mitigation	Contingency
R3	No real pilot organisation is available	4	4	16	Project lead	Seek access in Weeks 1–2; prepare synthetic scenarios	Use expert review plus scenario pilots
R4	Expert reviewers are unavailable	3	4	12	Project lead	Recruit early and provide short structured materials	Use supervisor and qualified substitutes
R5	Privacy or confidential information is collected during evaluation	2	5	10	Project lead	Synthetic data, minimum collection and clear participant notice	Delete unnecessary material and notify supervisor
R6	Legal or regulatory guidance is interpreted incorrectly	3	5	15	Project lead	Use official sources, traceability and decision-support disclaimer	Remove claims and seek specialist review
R7	Prototype defects produce incorrect results	3	4	12	Project lead	Manual calculations, deterministic test cases and version control	Freeze affected feature and issue correction
R8	Schedule slippage delays evaluation	4	4	16	Project lead	Weekly critical-path review and Week 10 buffer	Reduce UI polish before evaluation quality
R9	Source-selection bias distorts control library	3	4	12	Project lead	Academic, government and industry balance; traceability	Add perspectives identified by reviewers
R10	Public GitHub exposes confidential data or secrets	2	5	10	Project lead	Synthetic data, secret scan and pre-release review	Remove history, rotate secrets and notify supervisor
R11	Guidance or provider behavior changes during Part B	3	3	9	Project lead	Record versions and trigger change review	Update affected controls and note limits

ID	Risk	L	I	Score	Owner	Mitigation	Contingency
R12	Workload and wellbeing reduce quality	3	4	12	Project lead	Weekly workload cap, buffer and escalation	Reprioritize non-critical features and seek support

Appendix D- RACI Matrix

R= Responsible, A= accountable, C= Consulted, I=Informed. Each activity has one accountable role.

Activity	Hari	Academic supervisor	Cyber expert	Privacy expert	Pilot representative	User reviewer
Confirm scope and success criteria	R	A	C	C	C	I
Update evidence and control library	A/R	C	C	C	I	I
Design questionnaire and mapping	A/R	C	C	C	C	I
Define maturity scoring and gates	A/R	C	C	C	I	I
Build browser prototype	A/R	I	C	I	I	C
Prepare evaluation protocol	R	A	C	C	C	C
Conduct expert review	A/R	I	R	R	C	I
Conduct scenario pilot	A/R	C	C	C	R	C

Activity	Hari	Academic supervisor	Cyber expert	Privacy expert	Pilot representative	User reviewer
Analyse feedback and refine artefact	A/R	C	C	C	C	C
Approve final academic submission	R	A	I	I	I	I
Publish portfolio and handover	A/R	C	I	I	I	I

Appendix E- AI Use statement

Tools and purpose: ChatGPT and Claude used to help organise the proposal structure, review clarity, suggest project risk and stake holder categories, support diagram development and provide a starting code Skelton for the browser prototype. The evidence themes, project gap scope choices, maturity model decisions and final recommendations were developed from my assessment 1 research, topic brief and assessment 2 pitch work.

Sample prompts: “check whether these objectives are specific, measurable and feasible”; “identify project risks that may be missing from a ten-week GEN AI governance project”; “suggest a clear way to visualise the assessment workflow”; “review this paragraph for grammar without changing it meaning”.

Verification: references and factual claims were checked against the original scholarly paper or the relevant official website. The scoring logic will be checked using manual calculations and repeatable scenario tests. Diagram labels, project dates and risk treatments were reviewed against the final project scope.

Reflection on judgement: AI was useful for structure, language review and visualisation, but it was not treated as an authority. It can simplify genuine trade offs or suggest material that does not fit the project. For that reason, I retained responsibility for the evidence, design decisions, limitations and final written argument.